BBVA
Creating Opportunities

API Connect three-legged OAuth v1.0

Technical documentation

October 2022

Index

Index 2

Step 0 - What is BBVA API Connect? 3

Step 1 - Understanding the authentication method 3

1.1 OAuth 2.0 3

A. Authorization code flow with PKCE - 3 legged OAuth 3

Step 2 - Obtaining credentials 14

Step 3 - Calling the APIs 15

Appendix A - Definitions 16

Host domains 16

Date format 16

Appendix B - Tips and tools 17

PKCE generation for the Authentication code flow 17

ID token 17

Step 0 - What is BBVA API Connect?

BBVA API Connect is the way for a BBVA authorized client or partner (aka the "Third Party") to establish secure connections and communications with BBVA through APIs. BBVA API Connect uses the implementation of OAuth 2.0 Authorization framework described at RFC 6749.

This document describes the steps that the Third Party's technical team needs to understand in order to successfully establish secure connections and communications with BBVA, and hence, be able to call functional BBVA APIs taking full advantage of that security framework.

Step 1 - Understanding the authentication method

This document focuses on the authentication method to be used by the Third Party in order to use BBVA APIs on behalf of BBVA end customers.

1.1 OAuth 2.0

A. Authorization code flow with PKCE - 3 legged OAuth

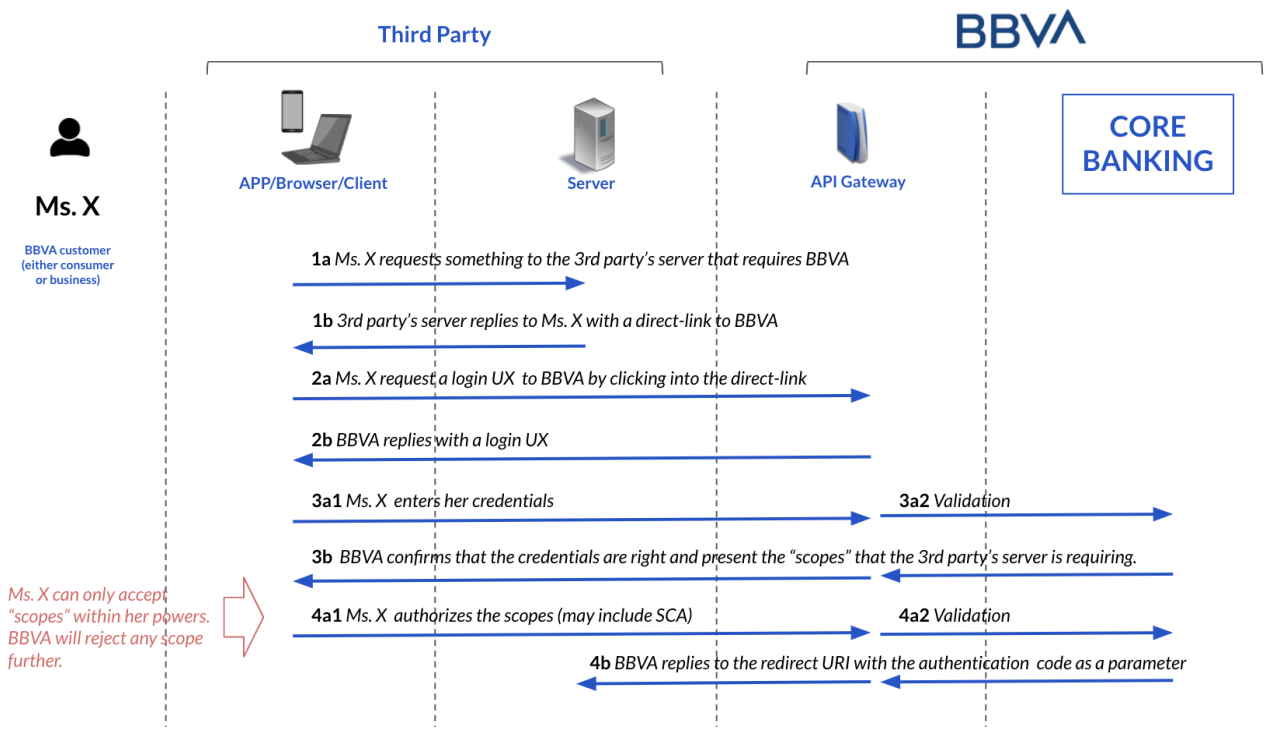
The 3 legged OAuth flow is used for the situations in which the Third Party wants to call an API on behalf of a BBVA customer. Those APIs/services require a previous authorization from the BBVA end customer.

BBVA uses the OAuth 2.0 Authorization code flow with Proof Key for Code Exchange (PKCE) in order to facilitate the BBVA customer to grant permission to the Third Party. If the BBVA customer consents in those permissions, BBVA will provide a code to the Third Party that will facilitate both an access token and a refresh token to call APIs on behalf of the BBVA end customer.

There are four endpoints related to this flow:

- Retrieve authorization code
- Retrieve access token
- Refresh access token
- Revoke access token

B1 - Retrieve authorization code



Once the Third Party requests a content or functionality that requires the consent of BBVA's end customer (Ms. X in the above flow), BBVA responds with a URI and that will lead BBVA's end customer to an authentication at BBVA as a customer(1b). This will be a direct and private communication between Ms. X and BBVA. If she authorizes the scopes that the server is requesting (4a), then BBVA will share an authentication code as a parameter of the redirection URI. See the following flow (4b).

Please note that once the Authorization code flow concludes, the Third Party needs an URL to redirect back into the navigation flow. Hence, that Redirect URI needs to be specified in every APP registration/connection configuration - see Step #2 - that expects to use APIs with the Authentication code flow.

The customer authorization process is supported by the BBVA websites or APPs, so the Third Party's UX will always be redirected to the BBVA API Connect user experience, hosted on those BBVA proprietary websites and APPs.

The BBVA's Oauth endpoint is `${host}/auth/oauth/v2/authorize` and uses the GET method. Please see the host domains definition to understand the right configuration for your systems.

Example: `GET https://apis.bbvaapimarket.com/auth/oauth/v2/authorize`

Parameters in HTTP request:

Name	Value	Description
client_id	Provided by BBVA in the Step #2.	ID assigned to the APP.

response_type	“code”.	Literal. Used for this authorization code grant type flow.
redirect_uri	URI to redirect the authorization flow once is over.	It is required if multiple redirect_uri's have been registered for this client.
code_challenge	The code_challenge value in the context of PKCE (RFC 7636).	Mandatory. See the OAuth 2.0 tutorial if necessary.
code_challenge _method	“plain” or “S256”	Mandatory. The method that was used to create the code_challenge.
scope	“openid”.	Optional. OpenID Connect is used to allow the Third Party to obtain basic profile information about the end BBVA customers.

Example (fake data)

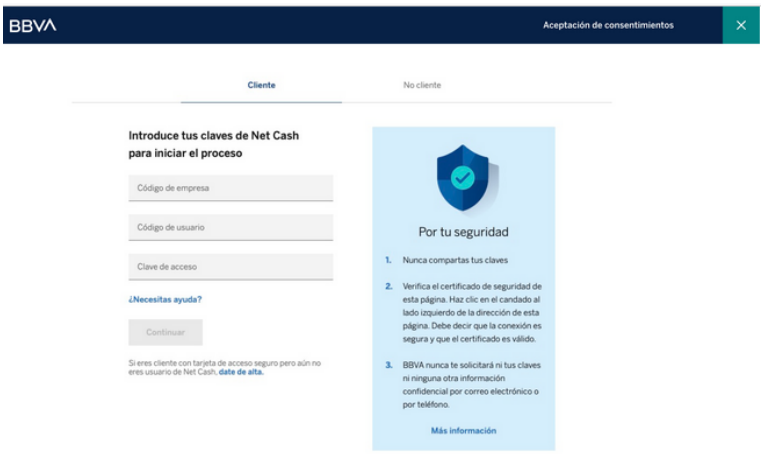
-Request

```
GET 'https://apis.bbvaapimarket.com/auth/oauth/v2/authorize \
--header 'Content-Type: application/x-www-form-urlencoded' \
--data-urlencode 'client_id=10dc4cfebf38138750b9b381' \
--data-urlencode 'response_type=code' \
--data-urlencode 'redirect_uri=https://www.mycompany.com/redirectedhere' \
--data-urlencode 'code_challenge=elU6u5zyqQT2f92GRQUq6PautAeNDf4DQPayyR0ek_c' \
--data-urlencode 'code_challenge_method=S256' \
--data-urlencode 'scope=openid'
```

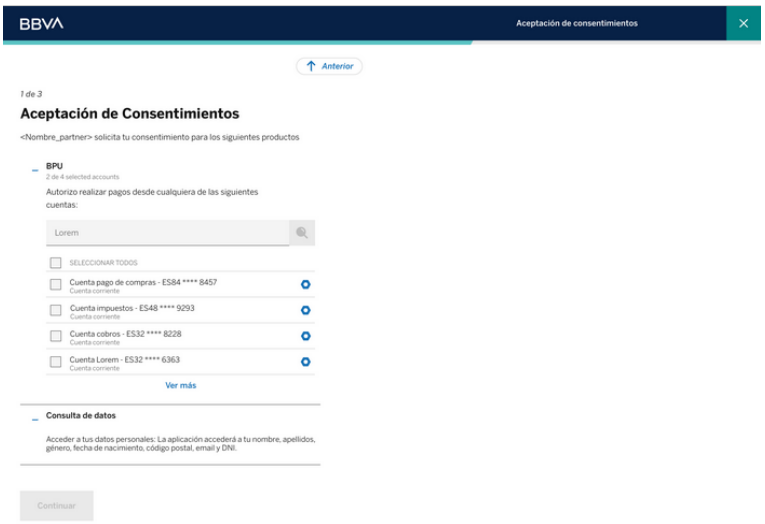
The user agent that calls the API will receive a UX from BBVA. That UX is going to request the digital channels’ credentials to the BBVA customer,, so that BBVA can confirm that the person that is interacting with the Third Party is actually a BBVA customer and can authorize the scopes that the Third Party is requesting.

Once BBVA has verified that the person interacting with the Third Party is really a BBVA customer, the consent approval flow starts. BBVA end customers can give their consent for the scopes that the Third Party is requesting. The steps of this flow are described below:

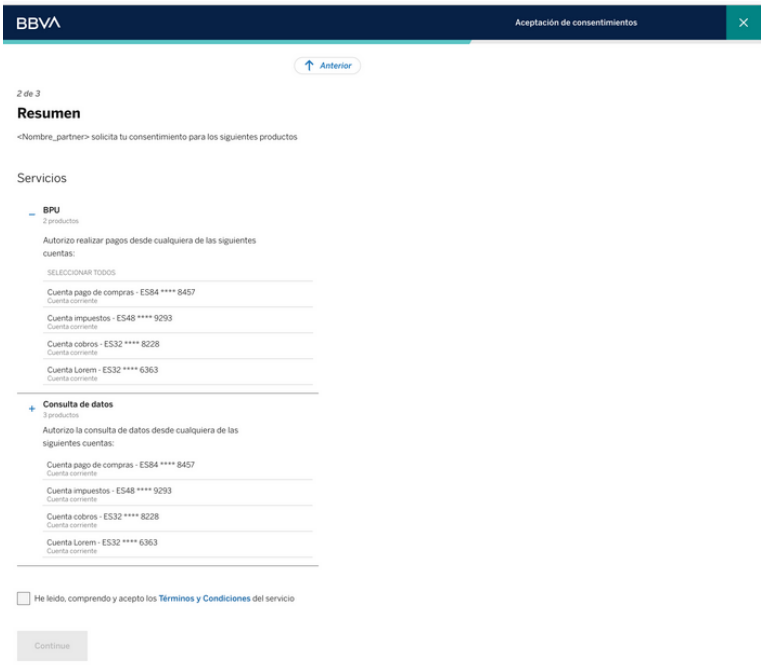
Step 1: BBVA customers use their digital channel credentials to authenticate themselves on BBVA servers.



Paso 2: BBVA customers review the scope of the consents and select those products or services for which they authorize this scope.



Paso 3: The customer is shown a summary of the consents being given to the Third Party and the products or services to which these consents apply.



Paso 4: To finalize the Consent Acceptance flow, the customer must validate the transaction by using a second authentication factor.

If the customer succeeds in the authentication to BBVA and also grants permission to the scopes, then the Third Party will receive the authorization_code attached to the redirect URI. Hence, the Third Party will be ready to exchange the authorization_code for an access_token.

If something goes wrong along the authorization_code retrieval flow, the Third Party will receive an error code to the redirect URI.

Error code API Response

Code 302 - Invalid scope

```
{
    "error":"invalid_scope",
    "error_description":"No registered scope value for this client has been requested"
}
```

Code 400 - Missing or duplicate parameters (HTML)

```
{
    "error":"invalid_request",
    "error_description":"Missing or duplicate parameters"
}
```

Code 400 - Invalid redirect_uri (HTML)

```
{
    "error":"invalid_redirect_uri",
    "error_description":"One or more redirect_uri values are invalid"
}
```

Code 400 - Invalid challenge or code challenge method (HTML)

```
{
    "error":"invalid_request",
    "error_description":"The code_challenge or code_challenge_methid is invalid"
}
```

Code 401 - Invalid credentials (HTML)

```
{
    "error":"invalid_credentials",
    "error_description":"The given client credentials were not valid"
}
```

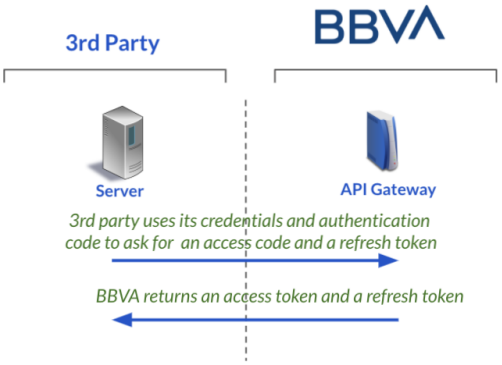
Code 500 - Invalid server error (HTML)

```
{
    "error":"invalid_request",
    "error_description":"The request failed due to some unknown reason"
```

```
}
```

B2. Retrieve access token

Once the Third Party gets the authorization code, it must be exchanged for an access token and a refresh token before the authorization code expires. By default, the authentication code has 300 seconds before it expires, so it must be exchanged for an access token and a refresh token before that period.



Those tokens - access and refresh - have their own expiration period that will depend on the agreement among the Third Party and BBVA, always with the privacy and security for the BBVA end customer at the center. Depending on the specific use case that the Third Party needs the consent for, after an expiration period the Third Party might need to run the authorization code retrieval flow, so the BBVA end customer would be asked for consent renewal.

In order to exchange the authorization_code for an access_token and a refresh_token, the endpoint at `${host}/auth/oauth/v2/token` and must be called using the method POST. Please see the host domains definition to understand the right configuration for your systems.

Parameters in HTTP request:

Name	Value	Description
client_id	Provided by BBVA in the Step #2.	ID assigned to the APP.
client_secret	Provided by BBVA in the Step #2.	Secret assigned to the APP.
grant_type	authorization_code.	Literal.
code	the authorization_code obtained at the end of the Retrieve authorization code flow.	String.

code_verifier	A random value of 43-256 characters that was used in the PKCE code_challenge.	See the OAuth 2.0 tutorial if necessary.
redirect_uri	String	Required should multiple redirect_uri's have been registered.

Code 200 API response:

Name	Value	Description
access_token	String	The Access Token for the given token request
token_type	"Bearer"	Literal. Always the same for the Client Credentials Flow.
expires_in	String	The expiration time, in seconds.
refresh_token	String	The Refresh Token for the given token request.
id_token	String	The jwt token that contains Claims about the authentication of the BBVA end customer. This value is only returned if the scope "openid" was indicated in the Retrieve authorization code flow.
id_token_type	String	JWT type This value is only returned if the scope "openid" was indicated in the Retrieve authorization code flow.
scope	"oob"	Issued scope. "oob" is the default one.

The "by default" expiration times are:

access_token=1,800 seconds (30 minutes).

refresh_token=604,800 seconds (7 days).

Please be aware that BBVA rotates the refres_tokens but the lifetime of a BBVA end customer consent does not extend when the tokens are rotated. The lifetime of a consent may be different depending on the use case and the agreement between the Third Party and BBVA.

Example (fake data):

```
POST 'https://apis.bbvaapimarket.com/auth/oauth/v2/token \
--data-urlencode 'client_id=10dc4cfebf38138750b9b381' \
--data-urlencode 'client_secret=bcd8121bcfdb4cga881ecafff2e0d514' \
--data-urlencode 'grant_type=authorization_code' \
--data-urlencode 'code=g0ZGZmNjVmOWIjNTk2NTk4ZTYyZGI3' \
```

```
--data-urlencode
'code_verifier=ztxjCf0XVDOU7sAhSLhyvISNM3d4qlp115wRVNLRibT1a6V68c01N57~Cae2fBhrZUwfWcHHu~XQR6DU0tsWaqs5DEbulhk7dDPphVlkKDLXccomXmSXNQYLVLdPm4Qu'
```

- Response

```
{
  "access_token": "d1146f8d-f565-4691-b5f6-122b781ea169",
  "token_type": "Bearer",
  "expires_in": 1800,
  "refresh_token": "i6mapTIAVSp2oJkgUnCACKKfZxt_H5MBLiqcybBBd04",
  "id_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxM”
}
```

Error code API Response

Code 400 - Invalid grant_type

```
{
    "error":"unsupported_grant_type",
    "error_description":"The given grant_type is not supported"
}
```

Code 401 - Invalid client_id / client_secret

```
{
    "error":"invalid_client",
    "error_description":"The given client credentials were not valid"
}
```

Code 400 - Invalid redirect_uri

```
{
    "error":"invalid_redirect_uri",
    "error_description":"One or more redirect_uri values are invalid"
}
```

Code 400 - code error, code_verifier error

```
{
    "error":"invalid_grant",
    "error_description":"The given grant is invalid"
}
```

B3. Refresh access token

The Third Party can renew the access token at any time before the refresh_token is expired. It also rotates the refresh_token as the Third Party will receive a new one too with the same expiration period as the previous one.

Please be aware that the lifetime of a consent may be different depending on the use case and the agreement between the Third Party and BBVA, and that any refresh_token or access_token will be invalid after that total content lifetime.

The BBVA's Oauth endpoint is `${host}/auth/oauth/v2/token` and uses the POST method . Please see the host domains definition to understand the right configuration for your systems.

Parameters in HTTP request:

Name	Value	Description
client_id	Provided by BBVA in the Step #2.	ID assigned to the APP.
client_secret	Provided by BBVA in the Step #2.	Secret assigned to the APP.
grant_type	refresh_token	Literal.
refresh_token	a valid refresh token	String

Code 200 API response:

Name	Value	Description
access_token	String	The Access Token for the given token request
token_type	"Bearer"	Literal. Always the same for the Client Credentials Flow.
expires_in	String	The expiration time, in seconds.
refresh_token	String	The Refresh Token for the given token request.

Example (fake data):

```
POST 'https://apis.bbvaapimarket.com/auth/oauth/v2/token \
--data-urlencode 'client_id=10dc4cfebf38138750b9b381' \
--data-urlencode 'client_secret=bcd8121bcfdb4cga881ecafff2e0d514' \
--data-urlencode 'grant_type=refresh_token' \
--data-urlencode 'refresh_token=i6mapTIAVSp2oJkgUnCACKKfZxt_H5MBLiqcybBBd04'
```

- Response

```
{
  "access_token": "eaf215f677bea1562026df05ecca202163a6c69f",
```

```
  "token_type": "Bearer",
  "expires_in": 1800,
  "refresh_token": "f6ecef2bf0d16d7c13a983616b30d72ca915ab65"
}
```

B4. Revoke access token

In case the Third Party needs to revoke any token, the endpoint to use is

`${host}/auth/oauth/v2/token/revoke`

and uses the POST method. Please see the host domains definition to understand the right configuration for your systems.

Parameters in HTTP request:

Name	Value	Description
client_id	Provided by BBVA in the Step #2.	ID assigned to the APP.
client_secret	Provided by BBVA in the Step #2.	Secret assigned to the APP.
token	The token as it was issued	String.
token_type_hint	Valid values are 'access_token' and 'refresh_token'.	Literal.

Code 200 API response:

Name	Value	Description
result	revoked	Literal.

Example (fake data):

```
POST 'https://apis.bbvaapimarket.com/auth/oauth/v2/token \
--data-urlencode 'client_id=10dc4cfebf38138750b9b381' \
--data-urlencode 'client_secret=bcd8121bcfdb4cga881ecafff2e0d514' \
--data-urlencode 'token=i6mapTIAVSp2oJkgUnCACKKfZxt_H5MBLiqcybBBd04' \
--data-urlencode 'grant_type=refresh_token'
```

- Response

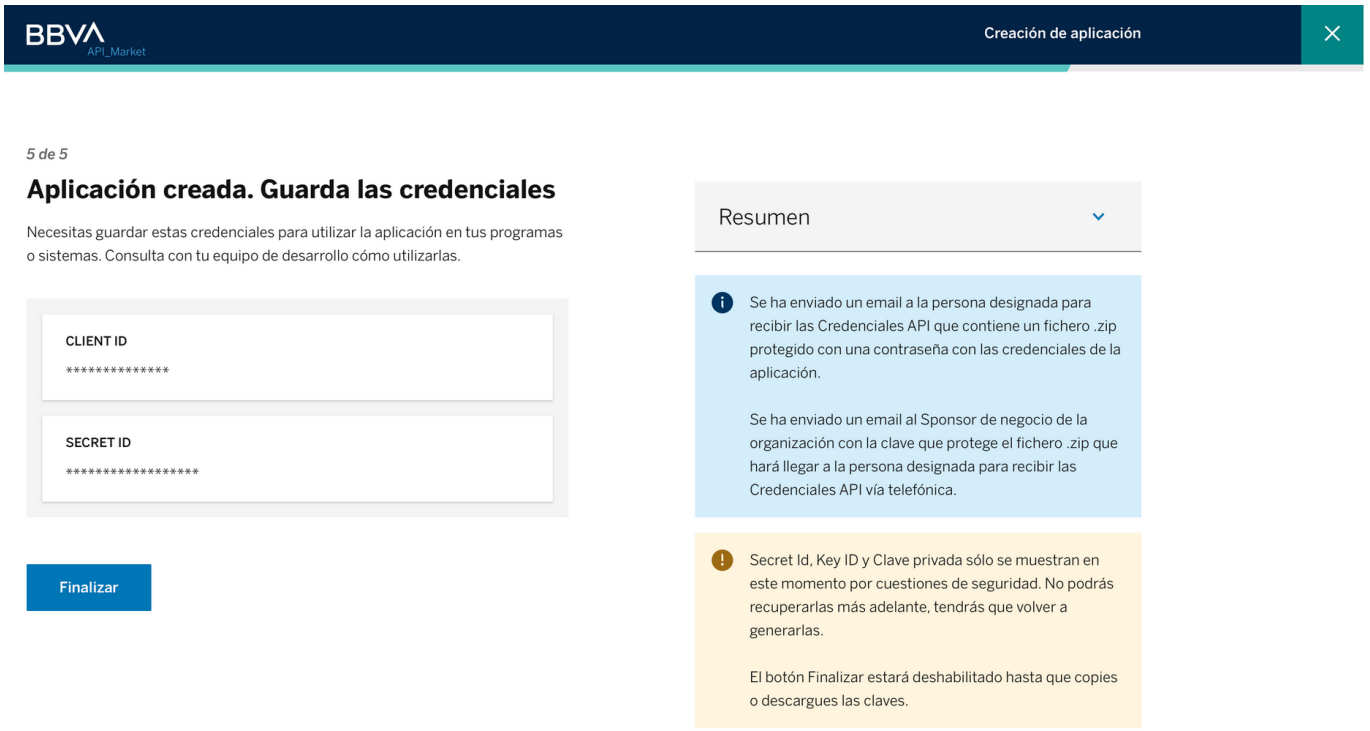
```
{
  "result": "revoked",
}
```

Step 2 - Obtaining credentials

Every API connection between BBVA and a Third Party must be previously configured. That configuration allows limiting the scopes of that connection - what can be done - and creating the specific credentials for the Third Party to be identified and framed to the assigned scopes.

Configuring an API connection is a straightforward process with BBVA, and we also call it “APP registration” in order to use the common language in API technologies. It is just about naming the connection plus assigning the specific APIs that are going to be used - among the ones that the Third Party has contracted with BBVA.

BBVA registers the APP both in SANDBOX and LIVE according to the terms agreed with the Third Party. BBVA will send via email the APP credentials to be used to call the BBVA APIs.



The set of credentials required for the connection and further communications are.

- Client ID
- Secret ID

Step 3 - Calling the APIs

The Third Party is ready to call BBVA APIs once it has the credentials for its APP, and understands how to use OAuth 2.0.

The regular steps for calling the BBVA APIs are:

- First- Get a valid access_token for the resources the API is asking for (see OAuth 2.0)
- Second - Generate a valid signature (see digital signature)
- Third - Build the header for the API call using the parameters in the table

Name	Value	Description
Authorization	String	The Access Token for the given token request (See OAuth 2.0)
Content-type	String	Litera "application/json".

- Fourth - Call the BBVA API

Now we are ready to use any of the BBVA APIs

```
curl --location --request {http_verb} '{gateway-url}{path}' \
--header 'Authorization: Bearer {access_token}' \
--header 'Content-Type: application/json' \
--data-raw '{request_body}'
```

Example

```
curl --location --request POST
'https://sbx.es.bbvaapimarket.com/foreign-exchange/v0/order-quotations' \
--header 'Authorization: Bearer ec066320-f531-43ee-8e93-e73c1dcb2269' \
--header 'Content-Type: application/json' \
--data-raw
'{"currencyPair":"EUR/GBP","side":"BUY","quotedAmount":{"value":10000,"currency":"GB
P"},"product":{"type":"FORWARD","settlementDate":"2020-12-14"},"aimedCommercialUse":
true,"commercialOperationReference":"factura32","accountId":"A50335918"}'
```

Appendix A - Definitions

Host domains

For SANDBOX and LIVE environments the `host` domain will be:

https://sbx.COUNTRYCODE. bbvaapimarket.com

https://apis.COUNTRYCODE. bbvaapimarket.com

Where the COUNTRYCODE is:

Country	COUNTRYCODE
Argentina	AR
Colombia	CO
Spain	ES
Mexico	MX
Perú	PE

However, for BBVA global APIs there won't be COUNTRYCODE as following:

https://sbx. bbvaapimarket.com

https://apis. bbvaapimarket.com

Please don't hesitate asking your designated BBVA Technical Account Manager if you don't know where your APIs are hosted.

Date format

In accordance to standard rfc1123 : "EEE, dd MMM yyyy HH:mm:ss Z"

Example: "Wed, 03 Jun 2020 19:48:45 +0200"

Appendix B - Tips and tools

PKCE generation for the Authentication code flow

https://tonyxu-io.github.io/pkce-generator/

ID token

The BBVA's APIs leverage the standard 7519 for ID Tokens. The ID Token is a security token that contains Claims about the authentication of a BBVA end customer by the BBVA authorization server. The ID token is represented by a JSON Web Token (JWT). For any further information we recommend seeing wjt.io.

The following Claims are used within the ID Token:

Name	Value	Description
sub	String	A locally unique and never reassigned identifier within the Issuer for the End-User
aud	String	Client_id of the Relying Party as an audience value
auth_time	A JSON number representing the number of seconds from 1970-01-01T0:0:0Z as measured in UTC until the date/time.	Time when the End-User authentication occurred
iss	A case sensitive URL using the https scheme	Issuer Identifier for the Issuer of the response
exp	A JSON number representing the number of seconds from 1970-01-01T0:0:0Z as measured in UTC until the date/time.	Expiration time on or after which the ID Token MUST NOT be accepted for processing.
iat	A JSON number representing the number of seconds from 1970-01-01T0:0:0Z as measured in UTC until the date/time.	Time at which the JWT was issued.
user_id	String	A locally unique and never reassigned identifier identifier within the Issuer for the End-user
custormer_id	String	A locally unique and never reassigned identifier identifier within the Issuer

		for the customer to whom the End-user (user_id) belongs

Example (fake data):

"id_token":"eyJhbGciOiJIUzI1NiJ9.eyJjdXN0b3JtZXJfaWQiOiI3MzQwMDY2MSIsInN1YiI6IjI0ODI4OTc2MTAwMSIsImF1ZCI6IjEwZGM0Y2ZlYmYzODEzODc1MGI5YjM4MSIsInVzZXJfaWQiOiIyNDgyODk3NjEwMDEiLCJhdXRoX3RpbWUiOiIxNjI2MDcyMzI5IiwiaXNzIjoiaHR0cHM6Ly9nYXRld2F5LmFwaWNoYW5uZWwtZ2xvYmFsLXdvcmstMDIud29yay5ldS5jbGQubmV4dGdlbi5pZ3J1cG9iYnZhLyIsImV4cCI6IjMyMTIzMjIxIiwiaWF0IjoiMTYyNjA3MjMyOSJ9.M1ZAnCAiO6Muuodu9MpGoRAvik7vQ_XXF3pGvYHHQwQ"

- Response (Payload)


```
{
  "custormer_id": "73400661",
  "sub": "248289761001",
  "aud": "10dc4cfebf38138750b9b381",
  "user_id": "248289761001",
  "auth_time": "1626072329",
  "iss": "https://gateway.apichannel-global-work-02.work.eu.cld.nextgen.igrupobbva/",
  "exp": "32123221",
  "iat": "1626072329"
}
```